Spear Phishing as a Violation of the Domain Knowledge Graph: Cross-Layer Inconsistency, Organizational Susceptibility, and the Rhythm-Leak Pitfall

Kamil Warpechowski
Kozminski University, Warsaw, Poland
NASK National Research Institute, Warsaw, Poland
kamil.warpechowski@kozminski.edu.pl

Bogdan Księżopolski
Kozminski University, Warsaw, Poland
bogdan.ksiezopolski@kozminski.edu.pl

***Abstract*—Spear phishing by external impersonation respects the victim's domain knowledge: the sender poses as a known role, and the content reads as normal. We argue the signal lies in its *inconsistency* with the organization's domain knowledge, modeled as a multiplex over one set of accounts—contacts, hierarchy, competencies, public footprint, platforms, routines, and temporal rhythm. On a graph-first synthetic organization of 150 personas, fusing the layers with the rhythm lifts AUC from 0.70 to 0.87 and removes every new-sender false alarm; a shuffle control falls to chance, and a control permuting only the OSINT layers attributes most of the gain to the contacts–rhythm pair, with OSINT adding a small but consistent margin. The gain is on the false-alarm side: cold impersonation remains almost undetected (sensitivity 0.04 at FPR 1%), and ablation shows the temporal-consistency feature carries most of the signal. On the real Enron corpus we expose an evaluation pitfall: a rhythm estimated on the full history inflates a rhythm-only detector to an apparent sensitivity of 0.73 at FPR 1%, which falls to 0.00 under a proper temporal split, whereas the multiplex keeps a sensitivity of 0.14 (AUC 0.82). A detector-relative susceptibility metric shows the attack channel, not the victim's rank, drives exposure** (Susc ≈ 0.96 **for cold impersonation at every seniority level), and graph and content fail on different attacks, fusing to near the better of the two in each regime. The OSINT layers remain synthetic: this validates a mechanism and an evaluation practice, not the detection of real intrusions.**

***Index Terms*—spear phishing, Business Email Compromise, domain knowledge graph, multiplex networks, cross-layer inconsistency, detector-relative susceptibility, leak-aware evaluation**

I. Introduction

A request lands in the CFO's inbox: the "CEO" asks for an urgent transfer. The wording is polished, the pretext plausible, and nothing in the content betrays the deception [1], [2]. Business Email Compromise caused adjusted losses of approximately $2.9 billion in 2023 [3]. Modern filters built on content and reputation classify mass campaigns at $\sim$98% accuracy [4], [5], but that figure is dominated by the mass tail; the rare targeted residual—spear phishing by *external impersonation* of a role or authority—evades them by design, because the message respects everything the victim knows: the right name, the right project, the right tone [6], [7], at a cost that language models keep lowering [8].

Our thesis is that such an attack is a violation of the organization's *domain knowledge graph*. We model this knowledge as a multiplex of relations over one set of accounts: contacts and hierarchy, supplemented by competencies, public footprint, platforms, routines, and the temporal rhythm of every account. A genuine relation is consistent across many of these layers at once; an impersonation appears in one layer but contradicts the others—a known name arriving without any OSINT trace, or off-rhythm. This *cross-layer inconsistency* is the signal—carried in practice mostly by the temporal rhythm and the contacts layer, with the OSINT layers adding a targeted margin—and it is invisible to any content filter.

Two questions follow, and we answer both under a leak-aware protocol. First, does cross-layer inconsistency separate targeted attacks from legitimate new senders—the case on which a contacts-only detector fails completely—and does the gain come from the layer structure rather than mere feature capacity? Second, what does the domain knowledge graph reveal about *who* is most exposed, and what happens to such detectors when their evaluation leaks?

The contributions are as follows.

1) The formalization of the domain knowledge graph as a multiplex with a per-pair coverage $C(s, v)$ and a temporal consistency tc, and of *cross-layer inconsistency* as a detection invariant for external impersonation (Sec. III).
2) A mechanism check on a graph-first synthetic organization: the multiplex lifts AUC from 0.70 to 0.87 and removes all new-sender false alarms, with a shuffle control at chance; a targeted OSINT-only shuffle attributes most of the gain to the contacts–rhythm pair, ablation shows that the rhythm carries most of the signal, and decorrelating the topology shows why the structural layers add little on a compact population (Sec. V).
3) A real structural-temporal multiplex built from Enron headers, and the *rhythm-leak pitfall*: a rhythm-only detector's apparent sensitivity of 0.73 falls to 0.00 under

a temporal split of the rhythm estimate, while the multiplex keeps a sensitivity of 0.14 (Sec. V-C).

4) A detector-relative susceptibility metric, with bootstrap confidence intervals, showing that the attack channel dominates the victim's rank (Sec. V-D); and the graph-vs-content boundary (Sec. V-E).

The scope is stated up front: the OSINT layers are synthetic even on the real graph, so this is a proof of mechanism and of evaluation practice. The complementary mode of targeted email—a compromised internal account that propagates a cascade—uses only the contacts layer and the rhythm and is treated in a separate study.

II. Related Work

The knowledge-side attack. Spear phishing draws its credibility from open-source intelligence (OSINT); automated harvesting of such traces has been studied since early work [9]. [6], [10] found that raw social and OSINT features added little beyond content and URLs—a caution we take seriously: OSINT helps as a *relation constructor*, a shared list or affiliation, and treating it as a flat feature is a known pitfall. Language models drastically lower the cost of personalization: automated campaigns match human experts in human-subject studies [8], and realistic OSINT traces can be generated synthetically [7]. Once content can be generated perfectly, the defense must exploit relations rather than style.

Spear-phishing and BEC detection. Targeted attacks differ from mass phishing in their personalization and context [4]; content-side classifiers such as hybrid ensembles over content and metadata [11] remain effective for the mass tail but inherit the content signal's blindness to clean-content deception. The effective methods for the targeted tail depart from content: [12] characterized lateral phishing across 113 million emails with an operational threshold of <4 FP/million, [13] targeted payload-free BEC in production, and per-sender behavioral profiles [14], [15], header and stylometry models [16], and relay-infrastructure analysis [17] all catch mail whose content reads as normal; BEC surveys trace its evolution and cost [18]. None of them represents the organization's knowledge as a graph, which is the gap this paper addresses.

Human and organizational susceptibility. Susceptibility depends on personality and context [19], rises under time pressure and persuasion cues [1], and is only partially moderated by awareness and decision style [2]. These works measure the *human* side; we measure a complementary, structural quantity—the exposure a detector leaves for a given role and attack channel (Sec. V-D).

Multiplex and heterogeneous graphs. The formalism for fusing multiple relations over one set of accounts is the multiplex network [20]–[23]. Heterogeneous GNNs learn to fuse relation types: HAN [24], HGT [25], MAGNN [26], and attributed-network embedding [27], [28]. Cross-view inconsistency as an anomaly signal is known in fraud detection [29], and graph structure attacks [30]–[32] and defenses [33]–[36] matter because an attacker can fabricate edges. To our knowledge, cross-layer inconsistency has not been operationalized as a domain knowledge graph of corporate email for security.

Evaluation rigor. ML detectors in security are easily inflated by leaks, unfair splitting, and headline AUC [37]; time-aware evaluation shows how temporal leakage distorts results [38]. The rhythm-leak pitfall of Sec. V-C is an instance of exactly this failure, made concrete for email.

III. Model

Definition 1 (Domain knowledge graph): A domain knowledge graph is $\mathcal{G} = (V, \{E_L\}_{L\in\mathcal{L}}, \{w_L\}, \tau)$, where V is the set of accounts, $\mathcal{L}$ is the set of relation *layers* over the *same* V (contacts, hierarchy, domain; OSINT layers from competencies, public footprint, platforms, events, routines, pretexts), $w_L \in (0, 1]$ is the confidence weight of a layer, and $\tau : V \to \mathcal{T}$ assigns to senders a *temporal rhythm* (active windows).

Two scalars summarize a sender–victim pair. The *domain-knowledge coverage* weights the layers in which the pair co-occurs,

$$C(s, v) \;=\; \sum_{L\in\mathcal{L}} w_L \, \mathbf{1}[(s, v) \in E_L] \,, \tag{1}$$

We use C and the weights w_L as a *design intuition* for why layer membership should carry signal, not as an operational score: the reported detectors are gradient-boosted trees over the per-layer membership vector and the temporal bit, which learn their own layer weights from data. and the *temporal consistency* tests whether the message arrives in the sender's rhythm, $tc(s, v, t) = \mathbf{1}[t \in \tau(s)]$; for a sender with no observed history $\tau(s)$ is undefined and we set $tc = 0$, so for cold senders the rhythm bit doubles as an unknown-sender indicator. In the Enron experiment of Sec. V-C this case never arises—every candidate sender passed a minimum-history filter—but in deployment $tc{=}0$ for a truly cold sender must be read as "unknown", not "off-rhythm".

Threat model. The attacker's goal is to deliver to victim v a message classified as legitimate. In external impersonation, s impersonates a role or authority, giving the impression of a high C while lacking real coverage in some of the layers (low structural consistency), possibly fabricating OSINT edges. Fabricating a footprint is cheap, and the fabrication sweep prices it: with 50% of attack edges forged the multiplex AUC drops from 0.87 to 0.74 (the sweep of the Tab. II event model; under the harsher ablation mix of Sec. V-B, where the OSINT margin is smaller, the same fabrication level costs less, $0.86 \to 0.82$), and given the event volume this corresponds to roughly 3–4 forged OSINT edges per targeted victim—cheap per victim, but visible in aggregate, because forged edges raise the score of a sender precisely where the legitimate new-sender mass also lives. The signal that remains is the joint consistency across layers that a fabricated edge does not create; this is the signal. A compromised internal account is the complementary case: $C(s, v)$ is high yet $tc = 0$; its propagation dynamics are the subject of the separate study, and here it appears only as the second attack channel of the susceptibility measurement.

Out of scope is an adaptive adversary with full knowledge of the graph.

Invariant: cross-layer inconsistency. A legitimate new sender sits outside the contacts layer but on an OSINT layer, and that consistency justifies them; an impersonator sits outside every layer, or on one layer that the others contradict. The detector operates on the vector of layer membership and its (in)consistency, leaving content aside. The invariant is testable by ablation: shuffling layer membership and rhythm destroys the structure it relies on (and, with it, the contacts and rhythm signals, so the control bounds rather than isolates the cross-layer contribution).

Definition 2 (Detector-relative susceptibility): The susceptibility of node v relative to a detector D at a fixed FPR, for an attack channel c, is the expected miss rate of attacks of that channel targeting v, $\mathrm{Susc}_{D,c}(v) = \mathbb{E}_{s\in\mathcal{A}_c(v)}\big[1 - \Pr[D \text{ detects } (s \to v)]\big]$, where $\mathcal{A}_c(v)$ is the set of attacking senders of v in channel c (external impersonation or a compromised contact).

Susc_D measures the residual exposure that a detector leaves, not the human susceptibility of the victim studied in [1], [19]; higher values mean *more* exposed.

We do not enumerate $\mathcal{A}_c(v)$; the group-level plug-in estimator of Sec. V-D measures Susc by attack channel and seniority. A worst-case variant taking the maximum over $\mathcal{A}_c(v)$ is a natural alternative.

IV. Method

Detectors and the shuffle control. For a sender–victim pair we compare three feature sets of increasing structure with a gradient-boosting classifier: contacts-only; a static multiplex adding the OSINT layers; and multiplex + rhythm, which further adds the temporal-consistency feature tc. Features encode layer membership and timing, never identity, so every detector is inductive. The shuffle control permutes layer membership and rhythm: if the signal is genuine cross-layer consistency, the control must collapse the advantage to chance. We also compare four explicit consistency measures (OSINT coverage; known sender off-rhythm; new sender on OSINT; entirely off-graph) against raw per-layer concatenation, and we ablate layers cumulatively, by forward selection and leave-one-out, and separately per threat (new senders vs. compromises). A topology-decorrelation knob ρ rewires contacts from intra- to inter-company to test whether the near-identity of the structural layers hides signal, and a fabrication sweep lets the attacker inject up to 50% false OSINT edges.

Events and splits. Each scored event is a (sender, victim, time bucket) triple with a legitimate or attack label and noise on both sides. On the legitimate side there are three kinds of sender: a known contact writing in rhythm; a *new-OSINT* sender, outside the victim's contacts but sharing an OSINT layer with them; and a *cold* sender outside every layer, which no relational detector can clear and which therefore sets a floor of false positives. On the attack side there are two channels: external BEC (outside all layers, off-rhythm) and a compromised known contact writing off-rhythm. Test victims are disjoint from training victims; headline numbers average 20 seeds; the headline metric is sensitivity at FPR 1%, with AUC reported alongside.

Real Enron multiplex and the leak control. From the Enron headers we build a real structural-temporal multiplex over 818 senders and $\sim$170k events. The "full" feature set on Enron is contacts, co-recipients (accounts addressed together), same mail domain, and the sender's rhythm, all derived from headers; *no OSINT layer is used on Enron*. The OSINT layers exist only in the synthetic case study, a deliberate split that keeps the real-data result free of synthetic overlays. The rhythm of a sender is estimated either from the *full* history (which leaks the evaluation period into the estimate) or from the *early* 60% of the period with evaluation on the later 40%; an off-hours audit varies the fraction of legitimate mail arriving outside the estimated rhythm.

Susceptibility estimator. Group susceptibility is the residual margin of the fusion detector at FPR$= 1\%$, $\mathrm{Susc}(\text{group}) = 1 - \text{sensitivity}_{\text{FPR}=1\%}$, the group-level plug-in estimator of Def. 2 for each channel c, broken down by attack channel and by the victim's seniority, with percentile bootstrap confidence intervals over seeds.

V. Case Study and Results

A. The organization and its layers

The case study (Fig. 1) is an ecosystem of 19 small firms from different sectors, N=150 accounts in total. Each firm is one managing director, one senior manager, and five to six specialists and analysts (19/19/57/55 accounts across the four levels), and neighboring firms are business partners, which yields 556 contact edges. The personas are synthetic, but the graph came first: the organization chart was fixed deterministically and every persona was then written into its own node, so the people a persona reports to, works with, and corresponds with outside the firm are other personas in the same population. Each persona is a record with a fixed eight-category schema (professional identity, relationships, competencies, public footprint, contact channels, temporal context, persuasion profile, and routine communications with plausible pretexts); these categories are exactly the OSINT material available to the attacker, and each maps to at most one layer (Tab. I). Two personas share an edge in a layer when they share a concrete, publicly observable field value; generic values are filtered out. The week is divided into T=28 six-hour buckets; a rhythm is the set of an account's active buckets (6 per persona); 15% of legitimate mail arrives off-rhythm and 25% of attacks mimic the rhythm.

B. Cross-layer inconsistency as a mechanism

Table II tests the invariant on the two cases of Fig. 1. Fusing the domain-knowledge layers with the rhythm lifts AUC from 0.70 (contacts only) to 0.87, while the layer/rhythm shuffle control drops to random (0.51), so the advantage stems from the actual layer and rhythm structure, not from feature capacity. Because this control shuffles every feature,

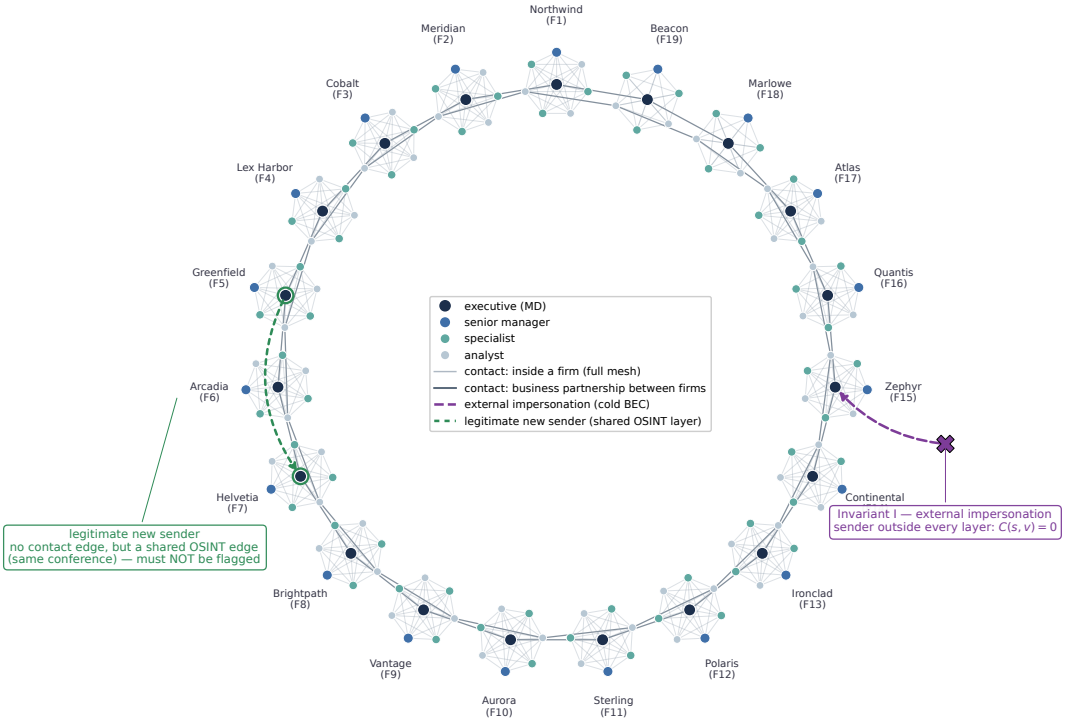


Fig. 1. The case-study organization, drawn from the population data: 19 firms on a ring of business partnerships, 150 accounts colored by seniority, and the real contacts layer (556 edges). Overlaid are the two cases the detector must separate: an external impersonation from outside every layer ($C(s, v)$=0), and a legitimate new sender connected only through a shared OSINT layer (the same conference), which must not be flagged.

TABLE I

MULTIPLEX LAYERS OF THE CASE STUDY: EDGE SEMANTICS, CONFIDENCE WEIGHT w_L (EQ. (1)), AND EDGE COUNT. THE WEIGHTS w_L ARE THE DESIGN INTUITION BEHIND EQ. (1); NO REPORTED DETECTOR USES THEM—THE GRADIENT-BOOSTED TREES LEARN THEIR OWN LAYER WEIGHTS FROM DATA.

Layer	Edge (shared fact)	w_L	#edges
Contacts	sender wrote to recipient	1.0	556
Hierarchy	same company	0.9	518
Domain	same mail domain	0.8	538
OSINT: conferences	shared conference	0.6	167
OSINT: certificates	shared certificate	0.6	389
OSINT: skills	shared skill	0.5	1144
OSINT: routine	shared communication pattern	0.4	397
OSINT: events	shared event	0.4	134
OSINT: platforms	shared platform/handle	0.4	534
OSINT: pretexts	shared plausible pretext	0.3	159
OSINT: interests	overlapping interests	0.3	53
Temporal	co-activity in the same hours	0.5	2528

20 *domain edges are cross-company: some personas carry a private e-mail address (field 15) in another company's corporate domain, and the domain cliques are built fr*

including contacts and rhythm, it does not by itself isolate the contribution of cross-layer *consistency*; we therefore added a targeted control that permutes the OSINT layer memberships independently per layer (preserving each layer's margins) while leaving contacts and rhythm intact: the full model reaches 0.86, the OSINT-shuffled variant 0.82, and a contacts+rhythm-only variant 0.83 (20 seeds each). Under this event mix, then, the joint OSINT contribution beyond contacts+rhythm is about 0.03 AUC: the bulk of the headline gain over contacts-only comes from the contacts+rhythm pair, and the OSINT layers add a small but consistent margin—which the per-threat analysis below shows is concentrated in the external-impersonation channel, where contacts and rhythm are structurally blind. The most striking difference is in the false alarms: the contacts detector flags 100% of legitimate new senders as attacks, the multiplex flags 0%; OSINT coverage rescues a legitimate sender who shares an observable fact with the victim. The signal is fragile, however: at 50% OSINT edge fabrication the advantage degrades toward the control ($0.87 \rightarrow 0.74$) as false traces erode it.

We state one circularity plainly. In the event model a legitimate new sender is *defined* as an account that sits on some OSINT layer of the victim, so part of the false-alarm removal

TABLE II

CROSS-LAYER INCONSISTENCY ON THE CASE-STUDY GRAPH (20 SEEDS): FUSING THE LAYERS WITH THE RHYTHM LIFTS AUC FROM 0.70 TO 0.87 AND REMOVES EVERY NEW-SENDER FALSE ALARM; THE SHUFFLE CONTROL FALLS TO CHANCE.

Model	AUC	new-sender FP
Contacts only	0.70 ± 0.01	1.00
Multiplex + rhythm	$\mathbf{0.87} \pm 0.01$	**0.00**
Multiplex (shuffled)	0.51 ± 0.01	—

is true by construction; a contacts-only detector cannot see that layer, the multiplex can. What is not tautological is the rest of the evidence: the full-feature shuffle, which keeps the feature marginals and falls to chance (0.51, below contacts-only), and the OSINT-only shuffle above, which isolates the small but real margin of the joint OSINT structure, so the gain depends on the actual joint structure of the features, though not necessarily on cross-layer consistency alone; the fabrication sweep, in which forged OSINT edges erode the advantage gradually rather than instantly; and the Enron result of Sec. V-C, where every layer is built from real headers.

The signal is concise consistency rather than capacity: four explicit consistency measures match the full per-layer concatenation: under a linear model they improve on it (0.860 vs 0.840 for the concatenation), and under trees they tie (0.860 vs 0.858), so their value lies in explainability and single-query deployment rather than in recall.

Figure 2 shows where the signal comes from, and this is the honest core of the mechanism check: each OSINT layer adds a marginal gain (contacts 0.57 → static 0.65), whereas the temporal consistency feature dominates and removing it sets AUC back to 0.65. The contacts-only value ranges 0.57–0.98 across the paper's event models, and each belongs to a different configuration: 0.57 is the ablation's mix here (40% known / 30% new-OSINT / 30% cold benign, both attack channels, 24 events per victim); 0.70 in Tab. II is the multiplex default (35% new-OSINT benign, fabricating BEC attackers, 14 events per victim); 0.98 at ρ=0 in Tab. III uses the three structural layers only, with attacks touching none of them. The lesson is that the contacts-only floor is a property of the benign new-sender mix, which is why every table states its configuration. Forward selection and leave-one-out analysis confirm it: temporal consistency alone reaches 0.826 of the full model's 0.862 (leave-one-out drop 0.21), while the hierarchy, domain, and co-activity layers are essentially redundant ($\leq$ 0.002). Together with the per-threat analysis below, this means that much of the AUC gain comes from the compromised-account channel, where the rhythm is decisive; for external impersonation the gain of the multiplex lies in removing false alarms on legitimate new senders.

Two controls bound this reading. First, the near-identity of the structural layers (contacts≈hierarchy≈domain, Jaccard $\geq$ 0.9) is an artifact of the generator, which assigns one domain per company; rewiring contacts across companies with the decorrelation knob (Tab. III) drops the Jaccard to 0.39 and

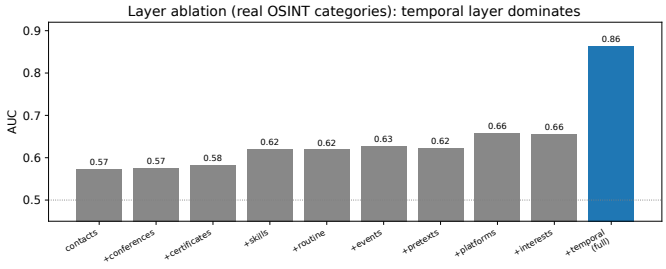


Fig. 2. Cumulative layer ablation: the eight OSINT layers add little on top of contacts (0.57 → 0.65) and the temporal-consistency feature carries the bulk of the signal (→ 0.86).

TABLE III

TOPOLOGY DECORRELATION (20 SEEDS): REWIRING CONTACTS ACROSS COMPANIES LOWERS THE OVERLAP OF THE STRUCTURAL LAYERS AND RAISES THEIR INDEPENDENT CONTRIBUTION.

Decorrelation ρ	Jaccard	indep. contrib.	contact AUC
0.0 (dense)	0.93	0.02	0.98
0.2	0.74	0.22	0.78
0.4	0.59	0.25	0.75
0.8 (decorrel.)	**0.39**	**0.25**	0.75

raises the independent contribution of the structural layers to 0.25 AUC, so the "effectively 3–4 layers" finding is a property of the compact population, not of the multiplex method. Second, the layers play distinct roles by threat (Fig. 3): for new senders the signal is carried by OSINT (alone 0.77) and time is useless (0.50), while for compromises the reverse holds (time 0.87, OSINT 0.50), so each family is critical for its own failure mode. Multiplex+rhythm leads across the whole noise range and for every $N \in \{40, \ldots, 150\}$, though absolute sensitivities at FPR 1% depend on the fraction of off-rhythm mail, which is why calibration on real data is needed. One apparent contradiction resolves by reading the feature sets, not the labels: in the sensitivity sweep the "contacts" column is contacts+rhythm (0.83–0.90 across the noise range, above the static multiplex's 0.65), while the ablation's contacts-only row (0.57) strips the rhythm bit—without it contacts fall below the static multiplex, with it they stay above; the rhythm, not the contact layer, is what tracks the noise.

C. The real Enron multiplex and the rhythm-leak pitfall

On the real Enron multiplex built from headers (contacts, co-recipients, domain, rhythm; no OSINT), the full multiplex reaches AUC 0.94 (legitimate traffic on-rhythm) versus 0.75 for contacts alone. Attack events are injected on top of the header-derived benign stream, in two channels: a *takeover* of a known sender (a genuine contact of the victim, sending off the sender's own rhythm in 75% of cases and mimicking it in 25%) and an *off-graph* sender drawn from the pool of corpus senders that are not contacts of the victim—every candidate sender has passed a minimum-history filter ($\geq$ 25 messages and a non-empty rhythm), so the cold-sender case of Sec. III does not arise here, and an off-graph event inherits the time bucket of the real message that motivated it. Roughly a quarter

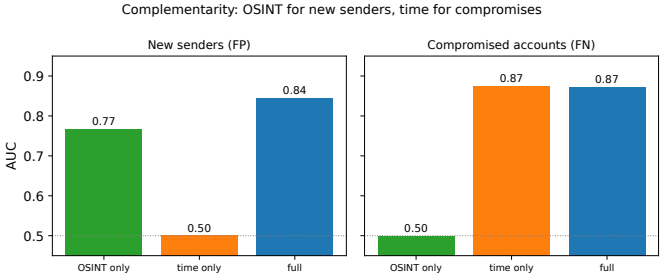


Fig. 3. Group ablation per threat. Left: new senders: OSINT is critical, time is useless. Right: compromises: the reverse. Each layer family is critical for its own failure mode.

of the events are takeovers, a quarter off-graph attacks, and half benign. In the leak control below, the rhythm *and* the temporal layers (contacts, co-recipients) are re-estimated on the early 60% window of each sender's history—an earlier version of this control split only the rhythm, while the structural layers were corpus-wide aggregates; since legitimate evaluation events are the real late-window messages themselves, corpus-wide contacts contained them by construction, inflating the full-multiplex sensitivity to an apparent 0.51. The domain layer stays static (the address is an identity attribute, not a history). Attack events are never part of the layer or rhythm estimation (both are built from the sender's own legitimate history), so the control isolates temporal leakage, not label leakage. The off-hours audit (Fig. 4) shows that the operational sensitivity was inflated: a realistic figure is ~ 0.5 rather than 0.88, but the multiplex advantage over the temporal layer alone rises with the off-hours fraction. Table IV applies the sharpest control, and this is the methodological result of the paper: under a temporal split of the rhythm estimate (rhythm from the early 60%, evaluation on the later 40%) together with off-hours traffic, the temporal layer alone collapses operationally (sensitivity at FPR $1\% \to 0$) while the full multiplex stays clearly ahead of the rhythm-only detector (AUC 0.82 vs 0.75; sensitivity 0.14 vs 0.00 at FPR 1%) even with every time-derived layer—rhythm, contacts, and co-recipients—estimated on the early window alone, and its advantage over time rises once the leakage is removed. A rhythm-only detector evaluated without a temporal split therefore reports an operational number inflated by leakage. Two readings of the drop to 0.00 need care. The temporal layer alone is a single binary feature, so its sensitivity at a fixed FPR is a step function: with the rhythm estimated on the full history, legitimate evaluation traffic is on-rhythm by construction and the off-rhythm threshold stays below FPR 1%; once more than 1% of legitimate mail falls off the estimated rhythm, no threshold meets FPR $\leq 1\%$ and the sensitivity is exactly zero, although the AUC is still 0.75. The leak is real (AUC $0.86 \to 0.75$), but its operational size is amplified by the threshold. To separate the step from the leak we re-ran the control at looser budgets: with the leaky full-history rhythm the sensitivity is 0.73 at FPR 1%, 2%, and 5% alike (the threshold already fits inside 1%), whereas under the temporal split it stays 0.00 even at FPR 5%—in the evaluation

TABLE IV

RHYTHM-LEAK CONTROL ON THE REAL ENRON GRAPH (20 SEEDS; RHYTHM, CONTACTS, AND CO-RECIPIENTS ALL ESTIMATED ON THE EARLY 60% WINDOW): ESTIMATING THE RHYTHM ON THE FULL HISTORY INFLATES THE TEMPORAL LAYER TO AN APPARENT SENSITIVITY OF 0.73; A PROPER TEMPORAL SPLIT DROPS IT TO 0.00, WHILE THE FULL MULTIPLEX KEEPS A SENSITIVITY OF 0.14 (AUC 0.82). BECAUSE THE TEMPORAL LAYER IS A SINGLE BINARY FEATURE, ITS SENSITIVITY@FPR IS A STEP FUNCTION: UNDER THE LEAKY ESTIMATE THE SAME 0.73 APPEARS AT FPR 1%, 2%, AND 5%, WHILE UNDER THE TEMPORAL SPLIT THE SENSITIVITY STAYS 0.00 EVEN AT FPR 5% (MORE THAN 5% OF LEGITIMATE EVALUATION-WINDOW MAIL FALLS OFF THE HONESTLY ESTIMATED RHYTHM, SO NO THRESHOLD QUALIFIES).

	temporal layer		full multiplex	
Rhythm (and structural layers) estimated from	AUC	sens.@1%	AUC	sens.@1%
full history (*with leakage*)	0.86	0.73	0.94	0.88
early window (*temporal split*)	0.75	0.00	**0.82**	**0.14**
early window + off-hours (*both*)	0.68	0.00	0.77	0.01

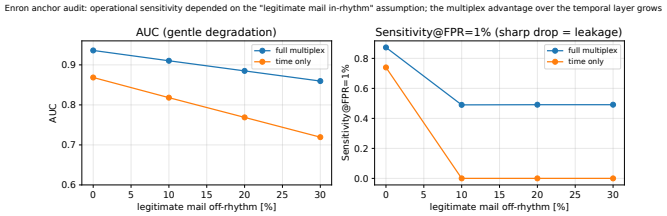


Fig. 4. Enron anchor audit. AUC (left) degrades gently with the off-hours traffic fraction; the operational sensitivity at FPR 1% (right) was inflated: the temporal layer alone collapses to zero, and the multiplex advantage rises with the off-hours fraction.

window more than 5% of legitimate mail falls off-rhythm, so no threshold of the binary feature qualifies at any of the three budgets. The collapse is therefore not an artifact of the 1% operating point alone; it is the step function interacting with an honestly estimated rhythm.

D. Detector-relative susceptibility

Table V breaks the misses of the fusion detector down by attack channel and by seniority. The channel, not the seniority, drives susceptibility. Cold impersonation leaves $\mathrm{Susc} \approx 0.96$ at every level, because no layer covers a sender from off-graph, and this sets a structural floor under the targeted tail. A compromised account is less dangerous (0.855 vs 0.962), since a known contact off-rhythm is a sharp, low-FP conjunction. Within the lateral channel we observe, but do not claim as a finding, an ordering that runs against the intuition that a richer graph embedding protects: executives, richest in domain-knowledge layers, are the *most* exposed ($\mathrm{Susc} = 0.924$), while the mid- and junior-level roles are the least exposed (0.838–0.840); the executive–junior gap is significant within the model (junior$-$executive sensitivity $+0.084$, bootstrap 95% CI $[0.062, 0.109]$). A plausible reading is that a richly embedded victim has many legitimate off-rhythm and cross-layer contacts, which widens the space in which an attack looks consistent. The reason we do not claim it is construction: the generator ties layer richness to seniority, so the direction of the ordering follows partly from that coupling,

TABLE V
DETECTOR-RELATIVE SUSCEPTIBILITY MEASURED BY THE FUSION DETECTOR (20 SEEDS, FPR= 1%; 95% BOOTSTRAP CIS OVER SEEDS): THE ATTACK CHANNEL, NOT THE VICTIM'S RANK, DRIVES EXPOSURE.

Dimension	Group	sens.@1% [95% CI]	Susc
Channel	External impers. (cold BEC)	0.038 [0.00, 0.115]	**0.962**
	Compromised acct (lateral)	0.145 [0.123, 0.168]	0.855
Seniority (lateral)	Executive	**0.076** [0.050, 0.106]	**0.924**
	Senior	0.135 [0.098, 0.173]	0.865
	Mid-level	0.162 [0.135, 0.190]	0.838
	Junior	0.160 [0.131, 0.190]	0.840
Seniority (cold BEC)	Executive	0.038 [0.000, 0.114]	0.962
	Senior	0.040 [0.000, 0.120]	0.960
	Mid-level	0.042 [0.000, 0.125]	0.958
	Junior	0.035 [0.000, 0.105]	0.965

TABLE VI
FUSION OF CONTENT WITH THE MULTIPLEX (AUC; 20 SEEDS): CONTENT AND GRAPH FAIL ON DIFFERENT ATTACKS.

Regime	Content only	Multiplex only	Fusion
Tell-tale (content trace)	0.997	0.862	**0.998**
Mimicry (BEC)	0.502	**0.862**	0.848

and it should be stress-tested under alternative assignments before any generalization. What is robust, and what we do claim, is that the channel dominates rank, and that seniority does not buy protection.

E. The graph–content boundary

Because the invariant is blind to cold off-graph impersonation, that case is the domain of content. Combining the graph signal with content (TF-IDF) in two regimes (Tab. VI), content separates the tell-tale regime almost perfectly (0.997) and the multiplex is redundant; in the mimicry regime (BEC) content is blind (0.502) and the signal is carried by the multiplex (0.862); fusion stays close to the better modality in each regime (0.998 and 0.848, the latter slightly below the multiplex alone), confirming that content and graph address different failure modes and that fusing them costs little. As a sanity check, on this small graph a single untuned multiplex GNN does not surpass the explicit hand-crafted features (AUC 0.78 vs 0.86 for LightGBM); at this scale the explicit membership features already capture the signal.

VI. DISCUSSION AND LIMITATIONS

What the mechanism check establishes. Cross-layer inconsistency is a real signal on the case-study graph, as the ablations show, and its practical value is on the false-alarm side: it removes every alarm on legitimate new senders that a contacts-only detector would raise. Its value on the recall side is limited, and we report reasons rather than hide it: the temporal-consistency feature carries most of the signal, the OSINT layers add only a small margin beyond contacts and rhythm (the OSINT-only shuffle control of Sec. V-B), and the structural layers add little on a compact population with one domain per company. The domain knowledge graph is thus a prioritization and triage tool for the impersonation mode, not a standalone product; for the cold off-graph sender it must be combined with content and process controls, as the fusion experiment confirms.

The rhythm-leak pitfall. The Enron result is a warning for the whole class of rhythm-based email detectors: a rhythm estimated on the evaluation period itself yields an apparent sensitivity of 0.73 that is inflated by leakage (and, for a binary rhythm feature, by the step at the FPR threshold). Any evaluation of such detectors should estimate the rhythm on an earlier window and audit the fraction of legitimate off-hours mail; under that protocol only the multilayer context retains operational sensitivity.

Limitations. First, the maliciousness is synthetic, and the OSINT multiplex advantage remains purely synthetic even on the real graph; no public corpus links real OSINT facts with labeled compromises, so this is a proof of mechanism rather than a measurement on real traffic. There is also some circularity: the synthetic population is generated graph-first, so detecting a violation of that structure is partly built in, which is reflected in the layer analysis. Second, the susceptibility measurement inherits these assumptions: the direction of the main conclusion (channel over rank) is robust within the model, but the exact values do not transfer to every organization, and the within-model rank ordering is partly definitional. Third, TF-IDF is a lower bound on what a modern content filter can do; a stronger content model could partially close the gap in the mimicry regime, though the failure-modes argument stands. Finally, the scale is limited (N=150 personas; Enron up to 818 senders), and the operational threshold of real mail (<4 FP/million [12]) remains far away.

VII. CONCLUSION

We formalized an organization's domain knowledge as a multiplex graph and showed that external impersonation violates it in a measurable way: cross-layer inconsistency separates targeted attacks from legitimate new senders on a graph-first case study (AUC $0.70 \rightarrow 0.87$, new-sender false alarms $100\% \rightarrow 0\%$, shuffle control at chance), with the honest finding that the rhythm carries most of the signal and the OSINT layers add a small, impersonation-targeted margin on top of the contacts–rhythm pair. On the real Enron corpus we built a structural-temporal multiplex from headers and exposed the rhythm-leak pitfall: an apparent sensitivity of 0.73 that falls to 0.00 under a proper temporal split, while the multiplex keeps a sensitivity of 0.14 (AUC 0.82). The value of the multiplex lies on the false-alarm side: cold impersonation from outside every layer remains almost undetected. The detector-relative susceptibility metric shows that the attack channel dominates the victim's rank, with a structural floor of $\mathrm{Susc} \approx 0.96$ for cold impersonation, and the fusion experiment locates the boundary between graph and content. The next step is validation on a corpus with real OSINT facts and labeled compromises, which would turn the mechanism into a measurement.

Data and Code Availability

The reproducibility package (population generator, layer construction, experiment code, and the computed results behind every table) is archived on Zenodo (DOI: to be inserted upon deposit). The Enron corpus is public [39].

Acknowledgment

During the preparation of this work the authors used Claude (Anthropic) to translate the manuscript from Polish into English and to copy-edit the prose; the authors reviewed and edited the content and take full responsibility for it.

References

[1] M. Butavicius, R. Taib, and S. J. Han, "Why people keep falling for phishing scams: The effects of time pressure and deception cues on the detection of phishing emails," *Computers & Security*, vol. 123, 2022.

[2] D. Sturman, J. C. Auton, and B. W. Morrison, "Security awareness, decision style, knowledge, and phishing email detection: Moderated mediation analyses," *Computers & Security*, vol. 148, 2025.

[3] Federal Bureau of Investigation, "Internet crime report 2023," 2024. [Online]. Available: https://www.ic3.gov/Media/PDF/AnnualReport/2023_IC3Report.pdf

[4] S. K. Birthriya, P. Ahlawat, and A. K. Jain, "Detection and prevention of spear phishing attacks: A comprehensive survey," *Computers & Security*, vol. 151, 2025.

[5] C. L. Tan, K. L. Chiew, K. S. Yong, S. N. Sze, J. Abdullah, and Y. Sebastian, "A graph-theoretic approach for the detection of phishing webpages," *Computers & Security*, vol. 95, 2020.

[6] P. Dewan, A. Kashyap, and P. Kumaraguru, "Analyzing social and stylometric features to identify spear-phishing emails," 2014.

[7] M. A. Brown, A. Gruen, G. Maldoff, S. Messing, Z. Sanderson, and M. Zimmer, "Web scraping for research: Legal, ethical, institutional, and scientific considerations," *Big Data & Society*, vol. 12, 2025.

[8] M. Bethany, A. Galiopoulos, E. Bethany, M. B. Karkevandi, N. Vishwamitra, and P. Najafirad, "Evaluating large language models' capability to launch fully automated spear phishing campaigns: Validated on human subjects," 2024.

[9] M. Edwards, R. Larson, B. Green, A. Rashid, and A. Baron, "Panning for gold: Automatically analysing online social engineering attack surfaces," *Computers & Security*, vol. 69, 2017.

[10] P. Dewan and P. Kumaraguru, "Facebook inspector (FbI): Towards automatic real-time detection of malicious content on facebook," *Social Network Analysis and Mining*, vol. 7, no. 1, 2017.

[11] P. Bountakas and C. Xenakis, "HELPHED: Hybrid ensemble learning PHishing email detection," *Journal of Network and Computer Applications*, vol. 210, 2022.

[12] G. Ho, A. Cidon, L. Gavish, M. Schweighauser, V. Paxson, S. Savage, G. M. Voelker, and D. Wagner, "Detecting and characterizing lateral phishing at scale," in *28th USENIX Security Symposium*, 2019.

[13] A. Cidon, L. Gavish, I. Bleier, N. Korshun, M. Schweighauser, and A. Tsitkin, "High precision detection of business email compromise," in *28th USENIX Security Symposium*, 2019.

[14] H. Gascon, S. Ullrich, B. Stritter, and K. Rieck, "Reading between the lines: Content-agnostic detection of spear-phishing emails," in *RAID*, 2018.

[15] G. Stringhini and O. Thonnard, "That ain't you: Blocking spearphishing through behavioral modelling," in *DIMVA*, 2015.

[16] S. Duman, K. Kalkan-Cakmakci, M. Egele, W. Robertson, and E. Kirda, "EmailProfiler: Spearphishing filtering with header and stylometric features of emails," in *IEEE COMPSAC*, 2016.

[17] S. Luo, E. Young, G. Ho, M. Schweighauser, E. Katz-Bassett, and A. Cidon, "Characterizing the networks sending enterprise phishing emails," 2024.

[18] H. F. Atlam and O. Oluwatimilehin, "Business email compromise phishing detection based on machine learning: A systematic literature review," *Electronics*, vol. 12, no. 1, 2023.

[19] T. Halevi, N. Memon, and O. Nov, "Spear-phishing in the wild: A real-world study of personality, phishing self-efficacy and vulnerability to spear-phishing attacks," 2015, sSRN 2544742.

[20] M. Kivelä, A. Arenas, M. Barthelemy, J. P. Gleeson, Y. Moreno, and M. A. Porter, "Multilayer networks," *Journal of Complex Networks*, vol. 2, no. 3, 2014.

[21] M. De Domenico, A. Solé-Ribalta, E. Cozzo, M. Kivelä, Y. Moreno, M. A. Porter, S. Gómez, and A. Arenas, "Mathematical formulation of multilayer networks," *Physical Review X*, vol. 3, no. 4, 2013.

[22] M. Magnani, B. Micenkova, and L. Rossi, "Combinatorial analysis of multiple networks," 2013.

[23] J. Garcia-Bernardo, J. v. d. Jeude, T. Aste, and G. Caldarelli, "The multilayer structure of corporate networks," *New Journal of Physics*, vol. 21, 2019.

[24] X. Wang, H. Ji, C. Shi, B. Wang, P. Cui, P. S. Yu, and Y. Ye, "Heterogeneous graph attention network," in *The Web Conference (WWW)*, 2019.

[25] Z. Hu, Y. Dong, K. Wang, and Y. Sun, "Heterogeneous graph transformer," in *The Web Conference (WWW)*, 2020.

[26] X. Fu, J. Zhang, Z. Meng, and I. King, "MAGNN: Metapath aggregated graph neural network for heterogeneous graph embedding," in *The Web Conference (WWW)*, 2020.

[27] V. Christophides, V. Efthymiou, T. Palpanas, G. Papadakis, and K. Stefanidis, "An overview of end-to-end entity resolution for big data," *ACM Computing Surveys*, vol. 53, no. 6, 2021.

[28] Y. Cen, X. Zou, J. Zhang, H. Yang, J. Zhou, and J. Tang, "Representation learning for attributed multiplex heterogeneous network," in *ACM KDD*, 2019.

[29] Z. Liu, Y. Dou, P. S. Yu, Y. Deng, and H. Peng, "Alleviating the inconsistency problem of applying graph neural network to fraud detection," in *ACM SIGIR*, 2020.

[30] D. Zügner, A. Akbarnejad, and S. Günnemann, "Adversarial attacks on neural networks for graph data," in *ACM KDD*, 2018.

[31] D. Zügner and S. Günnemann, "Adversarial attacks on graph neural networks via meta learning," in *ICLR*, 2019.

[32] E. Dai, W. Jin, H. Liu, and S. Wang, "Towards robust graph neural networks for noisy graphs with sparse labels," in *ACM WSDM*, 2022.

[33] X. Zhang and M. Zitnik, "GNNGuard: Defending graph neural networks against adversarial attacks," in *NeurIPS*, 2020.

[34] W. Jin, Y. Ma, X. Liu, X. Tang, S. Wang, and J. Tang, "Graph structure learning for robust graph neural networks," in *ACM KDD*, 2020.

[35] L. Cai, Z. Chen, C. Luo, J. Gui, J. Ni, D. Li, and H. Chen, "Structural temporal graph neural networks for anomaly detection in dynamic graphs," in *ACM CIKM*, 2021.

[36] Y. Wang, J. Zhang, Z. Huang, W. Li, S. Feng, Z. Ma, Y. Sun, D. Yu, F. Dong, J. Jin, B. Wang, and J. Luo, "Label information enhanced fraud detection against low homophily in graphs," in *The Web Conference (WWW)*, 2023.

[37] D. Arp, E. Quiring, F. Pendlebury, A. Warnecke, F. Pierazzi, C. Wressnegger, L. Cavallaro, and K. Rieck, "Dos and don'ts of machine learning in computer security," in *31st USENIX Security Symposium*, 2022.

[38] F. Pendlebury, F. Pierazzi, R. Jordaney, J. Kinder, and L. Cavallaro, "TESSERACT: Eliminating experimental bias in malware classification across space and time," in *28th USENIX Security Symposium*, 2019.

[39] B. Klimt and Y. Yang, "The Enron corpus: A new dataset for email classification research," in *ECML*, 2004.